

Grille NIST SP 800-115 ; Méthodologie des tests de sécurité

Présentation

Le NIST SP 800-115 organise les tests de sécurité en trois phases successives. Dans MUSA, cette structure guide la sous-phase 2.2 (audit technique). La colonne **Statut** reçoit : **R** (Réalisé), **NR** (Non réalisé), **NA** (Non applicable).

Phase 1 : Planification

Activité	Vérification	Statut	Réf. doc.
Définir les objectifs des tests	Objectifs documentés et approuvés		
Définir le périmètre des tests	Systèmes, réseaux, applications inclus/exclus		
Identifier les contraintes	Fenêtres horaires, systèmes critiques		
Obtenir les autorisations formelles	Autorisation écrite signée		
Sélectionner les techniques de test	SAST, DAST, réseau, social engineering		
Sélectionner les outils de test	Au moins 2 outils pour scans de vuln.		
Établir les règles d'engagement	Règles documentées et signées		
Identifier les coordonnées d'urgence	Contacts définis en cas d'incident		

Phase 2 : Exécution

Technique	Description	Outils typiques	Statut	Réf.
Découverte réseau	Cartographie des hôtes et services actifs	Nmap, Masscan		
Scan de vulnérabilités	Identification automatique des failles	OpenVAS, Nessus, Nikto		
Analyse statique (SAST)	Analyse du code source	SonarQube, Semgrep		
Test dynamique (DAST)	Test de l'application en exécution	OWASP ZAP, Burp Suite		
Test d'injection SQL	Injection dans formulaires et paramètres	SQLMap, manuel		
Test XSS	Injection de scripts dans l'application	XSSer, manuel		
Test d'authentification	Force brute, contournement d'auth.	Hydra, manuel		
Test d'autorisation	Accès non autorisés, escalade de privilèges	Manuel		
Test de configuration	Vérification des configs serveur/applicatif	Lynis, manuel		
Test de chiffrement	Vérification TLS, algorithmes	SSLScan, testssl.sh		

Phase 3 : Post-exploitation et rapport

Activité	Description	Statut	Réf. doc.
Nettoyage des systèmes	Suppression des outils et comptes de test		
Documentation des preuves	Captures d'écran, logs, extraits de code		
Classification des vulnérabilités	Critique / Élevé / Moyen / Faible		
Calcul du score de risque	$R = P \times I$, cotation CVSS si applicable		
Rédaction du rapport technique	Selon modèle MUSA (7 sections)		

Activité	Description	Statut	Réf. doc.
Vérification des correctifs	Re-test après application des correctifs		